



بنك الأفاق

AL-AFAQ BANK

Global Horizon Banking | وآفاق عالمية | سلامة استثمارية ..

تقرير تقييم مخاطر أمن المعلومات

Information Security Risk Assessment Report

تصنيف الوثيقة	سري — للاستخدام الداخلي فقط
مرجع الوثيقة	ISMS-DOC-06-3
الإصدار	1.0
تاريخ التقرير	12 سبتمبر 2026
معد الوثيقة	محمد عبدالغني العامري (رئيس فريق تقييم المخاطر السيبرانية)
مالك الوثيقة	أ. سارة الحربي (مدير أمن المعلومات - CISO)

سجل المراجعات (Revision History)

الإصدار	التاريخ	معد المراجعة	ملخص التعديلات
1.0	12 سبتمبر 2026	محمد عبدالغني العامري	الإصدار المعتمد الأول لتقرير تقييم مخاطر أمن المعلومات لبنك الأفاق الرقمية، بعد اكتمال حصر الأصول وسيناريوهات التهديد ومواءمة الضوابط.
0.2	28 أغسطس 2026	فريق تقييم المخاطر	تحديث نتائج تقييم ثغرات الأجهزة المحمولة وحادثة اللابتوب المفقود ومزامنة توقيت NTP ومجلدات الرواتب.

قائمة التوزيع (Distribution)

الاسم / الجهة	المسمى الوظيفي / الدور
د. نورة القحطاني	الرئيس التنفيذي (Chief Executive Officer)
أ. عبدالله المحيسن	رئيس مجلس الإدارة ولجنة المخاطر والامتثال
أ. سارة الحربي	مدير أمن المعلومات (Chief Information Security Officer - CISO)
م. خالد السالم	مدير إدارة تقنية المعلومات (Chief Technology Officer / IT Director)
أ. أحمد الغامدي	مدير إدارة المراجعة والتدقيق الداخلي (Internal Audit Director)

الاعتماد والتوقيع (Approval)

الاسم	المنصب	التوقيع	التاريخ
د. نورة القحطاني	الرئيس التنفيذي (CEO)	معتمد إلكترونياً	12 سبتمبر 2026
أ. سارة الحربي	مدير أمن المعلومات (CISO)	معتمد إلكترونياً	12 سبتمبر 2026
أ. عبدالله المحيسن	رئيس لجنة المخاطر ومجلس الإدارة	معتمد إلكترونياً	12 سبتمبر 2026

المحتويات (Contents)

1. المقدمة.
2. سياق تقييم المخاطر.
 - 2.1 السياق الداخلي والخارجي
 - 2.2 النطاق.
 - 2.3 معايير قبول المخاطر.
3. ملخص نتائج تقييم المخاطر. 11
 - 3.1 تقييم المخاطر القائم على الأصول:
 - 3.2 [تقييم المخاطر القائم على السيناريوهات
4. الملحق (أ): تقييم المخاطر التفصيلي.

الأشكال

الشكل 1: تقييم المخاطر القائم على الأصول.

الجداول

- الجدول 1: فريق تقييم المخاطر
- الجدول 2: الأشخاص الذين تمت استشارتهم. 8
- الجدول 3: ملخص نتائج تقييم المخاطر (القائم على الأصول).
- الجدول 4: ملخص نتائج تقييم المخاطر (القائم على السيناريوهات).

1. المقدمة (Introduction)

الهدف من هذا التقرير هو عرض نتائج عملية تقييم المخاطر التي تم إجراؤها في الفترة من 01 أغسطس 2026 م إلى 10 سبتمبر 2026 مضمن النطاق الموضح أدناه. وكان الغرض الرئيسي من هذه العملية هو تقييم المخاطر التي تواجه بنك الأفاق الرقمية وتحديد أي منها يمكن قبوله وأي منها قد يتطلب اتخاذ إجراءات للتعامل معه ومعالجته.

بمجرد اعتماد تقرير تقييم المخاطر هذا، سيتم تحديد إجراءات محددة ومناقشتها والاتفاق عليها، ثم توثيقها في خطة معالجة المخاطر لتتم إدارتها كجزء من نظام إدارة أمن المعلومات (ISMS).

تم توضيح المنهجية المتبعة في تقييم المخاطر هذا في وثيقة "عملية تقييم ومعالجة المخاطر" والتي تعد جزءاً من نظام إدارة أمن المعلومات.

- سياق ونطاق تقييم المخاطر.
- الأصول الواقعة ضمن النطاق (تشمل 28 أصلاً رئيسياً موزعة على 16 فئة).
- سيناريوهات المخاطر والتهديدات السيبرانية والتشغيلية المحددة للخدمات المصرفية.
- التهديدات الأمنية ونقاط الضعف الفنية المقترنة بكافة أصول البنك.
- مالكو المخاطر المعينون لكل أصل وعملية مصرفية.
- مستوى الخطر الأولي والمتبقي وفق مصفوفة التقييم 5×5.
- التوصيات المعتمدة بقبول الخطر أو اتخاذ إجراءات معالجته.
- أولوية المعالجة والجدول الزمني المقررة للتنفيذ.
- مبررات وأسباب القبول للمخاطر الواقعة ضمن حدود القبول المعتمدة.

يُعد هذا التقرير مدخلاً لمرحلة معالجة المخاطر ضمن هذه العملية، ويجب اعتماده وتوقيعه من قبل الإدارة العليا قبل المضي قدماً.

تم إجراء تقييم المخاطر هذا من قبل الأشخاص التاليين:

فريق عمل تقييم المخاطر (Risk Assessment Team)

الاسم	الدور في التقييم
محمد العامري	رئيس فريق مقيمي المخاطر (Lead Risk Assessor) — إدارة وتوجيه التقييم وصياغة التقرير
محمد الكشري	مقيم مخاطر مساعد (Assistant Risk Assessor) — حصر الأصول وتقييم الثغرات التقنية
محمد شماخ	محلل أول تهديدات سيبرانية (Cyber Threat Analyst) — تحليل التهديدات ونواقل الهجمات المصرفية
محمد الأصبحي	أخصائي حوكمة وتدقيق أمني (Security Controls Specialist) — موازنة ضوابط ISO 27001 و SAMA CSF

الأشخاص الذين تمت استشارتهم (People Consulted)

في إطار تنفيذ منهجية التقييم وضمان الشمولية التشغيلية، تمت استشارة ومقابلة المسؤولين وأصحاب المصلحة الموضحين في الجدول 2 أدناه:

الاسم	المسمى الوظيفي	الموقع / الإدارة
م. فهد العتيبي	مدير تقنية المعلومات	المقر الرئيسي — الرياض (مركز البيانات الرئيسي)
أ. خالد الشمري	مديرة الموارد البشرية والعمليات الإدارية	المقر الرئيسي — الرياض (إدارة الموارد البشرية HR)
أ. سارة الحربي	مدير أمن المعلومات	المقر الرئيسي — الرياض (مركز البيانات الرئيسي)
أ. أحمد الغامدي	مدير إدارة المراجعة والتدقيق الداخلي	المقر الرئيسي — الرياض (إدارة التدقيق الداخلي)

2 سياق تقييم المخاطر (Risk Assessment Context)

يوضح هذا القسم الأسباب التي دعت إلى إجراء تقييم المخاطر، والمجالات التي كانت ضمن نطاقه، والمعايير التي تم تطبيقها لتحديد المخاطر التي يوصى بقبولها.

2.1 السياق الداخلي والخارجي (Internal and External Context)

تم تحديد السياقين الداخلي والخارجي لتقييم المخاطر استناداً إلى وثيقة 'سياق المنظمة والمتطلبات والنطاق (ISMS-DOC-04-1)'، وجاءت دوافع ومبررات التقييم على النحو التالي:

السياق الاستراتيجي والرقابي: يأتي هذا التقييم كمتطلب حاسم وإلزامي لتطبيق متطلبات المعيار الدولي لأمن المعلومات ISO/IEC 27001:2022 داخل بنك الآفاق الرقمية، حيث يُعد تقييم المخاطر حجر الزاوية في بناء وتشغيل نظام إدارة أمن المعلومات (ISMS). وقد قرر مجلس إدارة البنك والإدارة التنفيذية السعي للحصول على الشهادة الرسمية للمعيار لتعزيز ثقة العملاء والشركاء والمودعين، وإثبات امتلاك البنك لأعلى مستويات الحصانة في حماية المعاملات والأرصدة المالية.

السياق الخارجي وتحديات التهديدات: يعمل بنك الآفاق الرقمية في بيئة مصرفية شديدة التنافسية في المملكة العربية السعودية تشهد تحولاً رقمياً متسارعاً. ويواكب هذا التحول تشديد رقابي صارم من البنك المركزي السعودي (SAMA) عبر إطار الأمن السيبراني (Cybersecurity Framework - CSF)، ولوائح حماية البيانات الشخصية (PDPL)، وقواعد مكافحة الاحتيال المالي. لذا، فإن إجراء التقييم المنهجي للمخاطر على الأصول المصرفية الحيوية يُعد وسيلة أساسية لتجنب العقوبات التنظيمية، وحماية سمعة البنك، والحفاظ على استمرارية الأعمال المصرفية.

السياق الداخلي والبيئة التشغيلية: يدير البنك بنية تحتية هجينة معقدة تضم مركزي بيانات رئيسيين (الرياض) واحتياطين للكوارث (جدة)، بالإضافة إلى خدمات سحابية مستضافة على منصة AWS. كما تشمل البيئة الداخلية تشغيل أكثر من 2,000 جهاز لابتوب للموظفين، وأنظمة مصرفية موروثة (Legacy Core Banking)، وبرمجيات قديمة لإدارة الرواتب (تطبيق سيبيرولا - Syberola). وقد أظهرت الحوادث الأمنية السابقة (مثل فقدان لابتوب مسؤول التسويق، وتفاوت توقيت الخوادم NTP بمقدار 7 دقائق، ومحاولات التصيد الإلكتروني) ضرورة إجراء تقييم شامل لمعالجة كافة مكامن الضعف.

2.2 نطاق التقييم (Scope)

يحدد هذا التقرير بدقة الحدود التشغيلية والتقنية والجغرافية لعملية التقييم، وما يشمله النطاق وما يقع خارجه:

ما يشمله النطاق (In-Scope):

- الأنظمة المصرفية الأساسية (Core Banking System) وقواعد بيانات العملاء والحسابات والودائع.
- قنوات الصيرفة الرقمية للعملاء: الخدمات المصرفية عبر الإنترنت وتطبيقات الهواتف الذكية (Android & iOS).
- بوابات الدفع الوطنية والدولية وشبكات التحويل المالي (مدى Mada، نظام سريع SARIE، شبكة سويفت SWIFT).
- أجهزة المستخدم النهائي لجميع منسوبي البنك (2,000 لابتوب ومحطة عمل مكتبية) وبيئة العمل عن بُعد.
- مراكز البيانات في الرياض وجدة، والخوادم الافتراضية، ومستودعات التخزين السحابية (AWS S3).
- أنظمة الهوية المركزية والدليل النشط (Active Directory) ونظام البريد الإلكتروني والاتصالات المؤسسية.
- أنظمة الموارد البشرية والرواتب (نظام سيبيرولا التراشي) ومستودعات حفظ بيانات الموظفين.
- ما يقع خارج النطاق (Out-of-Scope): الأنظمة المستقلة المعزولة تماماً في شبكات الاختبار والمختبرات التقنية التي لا ترتبط بالشبكة المصرفية ولا تحتوي على بيانات بنكية حقيقية.
- الأنظمة والخدمات التقنية التابعة لمجموعات استثمارية أو شركات شقيقة مستقلة قانونياً وإدارياً عن البنك.

2.3 معايير قبول المخاطر (Risk Acceptance Criteria)

من أجل التوصل إلى استنتاجات بشأن المخاطر ذات المستوى المرتفع بما يكفي ليتطلب معالجة إضافية، تم استخدام عدة معايير لتقييم قبول المخاطر.

- يُوصى بقبول الخطر إذا استوفى واحداً أو أكثر من المعايير التالية:
- احتساب درجة الخطر بـ 4 أو أقل.
- وجود تغييرات معلومة تعني أن الخطر سيستمر لمدة ثلاثة أشهر أو أقل.
- الاتفاق على أن الفوائد المحتملة (المباشرة أو غير المباشرة) تفوق الأثر المتوقع.

وفي كل حالة، سيتم ذكر أسباب التوصية بقبول الخطر.

3 ملخص نتائج تقييم المخاطر (Risk Assessment Results Summary)

يظهر ملخص نتائج تقييم المخاطر في الجدول 3 أدناه. وترد التفاصيل الكاملة للتقييم، بما في ذلك أنواع المخاطر، ومالكو المخاطر، والضوابط القائمة، وكيفية تحديد مستويات المخاطر، في الملحق (أ) المرفق. أبرز مجالات القلق والمخاطر الحرجة التي تم تحديدها وتستوجب المعالجة الفورية:

- ضعف حماية وتشفير الأجهزة المحمولة (Mobile Endpoints): أظهر التقييم أن استمرار تشغيل 2,000 جهاز محمول للموظفين دون تفعيل تشفير كامل للأقراص (BitLocker) يشكل خطراً حرجاً على سرية بيانات العملاء وسجلات البنك في حال السرقة أو الفقدان (كما حدث في حادثة لابنتوب مدير التسويق بالخارج).
- التهديد المتزايد من هجمات الهندسة الاجتماعية والتصيد: تصاعد هجمات التصيد الإلكتروني والهندسة الاجتماعية الموجهة ضد موظفي البنك، وضعف مستوى الوعي الأمني (حيث لم تتجاوز نسبة إبلاغ الموظفين عن الرسائل المشبوهة 8% سابقاً)، مما يسهل اختراق الشبكة الداخلية ونشر برمجيات الفدية (Ransomware).
- فجوات الأنظمة التراثية والموروثة والصلاحيات المفرطة: استمرار العمل ببرمجيات قديمة غير مدعومة من المورد مثل تطبيق الرواتب (سبييرولا - Syberola)، واعتمادها على صلاحيات مسؤول محلي موروثه تفتح ثغرات تصعيد الصلاحيات عبر بروتوكولات قديمة (SMBv1 / NTLMv1).
- عدم موثوقية سجلات التدقيق والمزامنة الزمنية: وجود تفاوت وانحراف زمني بمقدار 7 دقائق في مزامنة توقيت الخوادم (NTP Drift)، مما يعيق التحقيق الجنائي الرقمي وتتبع تسلسل الهجمات واكتشاف العمليات الاحتيالية في الوقت الفعلي.
- مخاطر البيانات السحابية المشتركة: تخزين ومشاركة بيانات ومعلومات مصرفية على مستودعات سحابية خارجية (AWS S3) دون تطبيق سياسات صارمة لمنع تسريب البيانات (DLP) وتشفير البيانات أثناء التخزين.

3.1 تقييم المخاطر القائم على الأصول (Asset-based Risk Assessment)

يلخص الجدول 3 أدناه نتائج تقييم المخاطر لأبرز عشرة أصول مصرفية حيوية، محدداً التهديدات ونقاط الضعف ومستوى الخطر الأولي وقرار المعالجة:

الرقم	الأصل	التهديد	نوع الخطر	مالك الخطر	مستوى الخطر	القرار	الملاحظات
1	قاعدة بيانات النظام المصرفي الأساسي (Core) (Banking DB)	هجوم فدية وتشفير البيانات أو تسريب أرصدة ومعاملات العملاء	أمني / سيبراني	مدير العمليات المصرفية	حرج (16)	معالجة (Treat)	تطبيق التشفير الشامل TDE وعزل الشبكة وتفعيل النسخ المعزول غير القابل للتعديل (Immutable Backups).
2	الأجهزة المحمولة للموظفين (2,000) لابتوب ومحطة عمل	فقدان أو سرقة الأجهزة وسحب البيانات الحساسة بدون تشفير	أمني / تشغيلي	مدير البنية التحتية IT	حرج (16)	معالجة (Treat)	إلزامية تفعيل تشفير BitLocker لـ XTS-AES 256 مع إقفال منافذ USB وإلغاء صلاحيات المسؤول المحلي.
3	تطبيقات الصيرفة الرقمية (Mobile Internet & Banking)	استغلال ثغرات الويب وAPI والتلاعب بالمعاملات والتحويلات	سيبراني / سمعة	رئيس القنوات الرقمية	عالي (12)	معالجة (Treat)	تطبيق جدار حماية التطبيقات WAF واختبارات الاختراق الدورية وتفعيل المصادقة الثنائية الإلزامية.
4	خوادم الدليل النشط والدومين (Active) (Directory)	الاستيلاء على حسابات المسؤولين وتصعيد الصلاحيات الشاملة	سيبراني / بنية تحتية	مدير الأنظمة والشبكات	عالي (12)	معالجة (Treat)	تطبيق بنية Tiered Admin وحظر بروتوكولات NTLMv1/SMBv1 واستخدام إدارة الحسابات المتميزة PAM.
5	بوابات الدفع وشبكة سويفت (SWIFT) Alliance & (Mada)	اعتراض أوامر الدفع والاحتيال المالي المتقدم	مالي / امتثال	مدير الخزينة والمدفوعات	عالي (12)	معالجة (Treat)	الامتثال الكامل لبرنامج أمن العملاء SWIFT CSP وعزل شبكة المدفوعات وتفعيل التوقيع المزدوج.
6	نظام الرواتب التراثي (تطبيق) سيبرولا - (Syberola)	استغلال ثغرات غير مرقعة واعتراض ملفات مسيرات الرواتب	تشغيلي / تقني	مديرة الموارد البشرية	متوسط (9)	قبول مشروط (Accept)	يُقبل مؤقتاً لمدة شهرين حتى استبداله بالنظام الجديد للرواتب، مع عزل السيرفر ومراقبة الوصول.
7	المستودعات السحابية (AWS S3 Cloud Buckets)	انكشاف البيانات الحساسة للعامة نتيجة خطأ في إعدادات الأدونات	أمني / تنظيمي	مدير السحابة والتحول الرقمي	عالي (12)	معالجة (Treat)	تفعيل S3 Block Public Access إجبارياً وتشفير KMS وإجراء تدقيق يومي عبر أداة CSPM.
8	خوادم السجلات والتحليل الأمني (SIEM &) (NTP Servers)	انحراف التوقيت (7 دقائق) وفقدان السجلات الجنائية الرقمية	أمني / تدقيق	مدير مركز العمليات SOC	متوسط (8)	معالجة (Treat)	مزامنة NTP مركزية مع خادم البنك المركزي السعودي وحماية السجلات من التعديل (WORM storage).

9	البنية التحتية للنسخ الاحتياطي (Backup) (Repositories)	تدمير أو تشفير النسخ الاحتياطية بواسطة برمجيات الفدية	استمرارية أعمال	مدير العمليات والتعافي	عالي (12)	معالجة (Treat)	تطبيق استراتيجية 1-2-3 وتخزين نسخة معزولة الهواء (Air-gapped) في مركز بيانات جدة واختبار الاستعادة.
10	مجلدات ومستودعات الموارد البشرية المشتركة (HR) (Shares)	اطلاع موظفي تقنية المعلومات أو غير المخولين على بيانات الرواتب	خصوصية / تنظيمي	مديرة الموارد البشرية	متوسط (6)	معالجة (Treat)	إلغاء أذونات الدومين العامة وحصر الوصول بفريق الرواتب وتفعيل التنبيهات الفورية للوصول غير المعتاد.

3.2 تقييم المخاطر القائم على السيناريوهات (Scenario-based Risk Assessment)

يلخص الجدول 4 أدناه نتائج تقييم المخاطر بناءً على سيناريوهات التهديد الواقعية التي تواجه البنية المصرفية، محدداً وصف السيناريو ومستوى الخطر الأولي والقرار الموصى به:

الرقم	ملخص الخطر	وصف سيناريو الخطر	نوع الخطر	مالك الخطر	مستوى الخطر	القرار	الملاحظات
1	إصابة الشبكة بفدية عبر البريد الإلكتروني	قيام موظف بفتح رابط تصيد أو مرفق خبيث مما يؤدي إلى تثبيت برمجية فدية وتشفير قواعد البيانات المصرفية ومطالبة البنك بفدية مالية.	سيبراني / تشغيلي	مدير أمن المعلومات (CISO)	حرج (16)	معالجة (Treat)	نشر فلترة البريد المتقدمة Defender for Office 365، وتثبيت زر التبليغ في Outlook، وإجراء محاكاة تصيد دورية.
2	تسريب بيانات العملاء عبر لابتوب مسروق	فقدان أو سرقة جهاز محمول لمسؤول إداري أثناء السفر دون تفعيل تشفير القرص، مما يمكن المهاجم من استخراج بيانات العملاء المالية ونشرها.	أمني / قانوني	مدير البنية التحتية IT	حرج (16)	معالجة (Treat)	التشفير الإلزامي لكافة الأجهزة عبر Intune BitLocker، مع تفعيل خاصية المسح عن بُعد وتشفير السجلات.
3	استغلال ثغرات التطبيقات التراثية	استغلال مهاجم لثغرات غير مرقعة في تطبيق الرواتب القديم 'سيبيرولا' واستخدام صلاحيات المسؤول المحلي المخزنة للتنقل الأفقي داخل الشبكة.	بنية تحتية / أمني	مدير البنية التحتية IT	متوسط (9)	قبول مشروط (Accept)	يُقبل الخطر مؤقتاً بضمانات عزل الشبكة وتطبيق LAPS لتغيير كلمات مرور الحسابات المحلية كل 30 يوماً حتى إلغاء التطبيق.
4	اعتراض واجهات البرمجة المصرفية (API)	هجوم وسيط (Man-in-the-Middle) أو تلاعب بحزم البيانات المرسلّة بين تطبيق الهاتف المحمول وخوادم البنك لتحويل مبالغ غير مشروعة.	سيبراني / مالي	رئيس القنوات الرقمية	عالي (12)	معالجة (Treat)	تطبيق ربط الشهادات الرقمية (SSL) (Pinning)، وتشفير الحمولة من النهاية للنهاية، وفحص أمني لجميع واجهات API.
5	فشل التحقيق الجنائي بسبب	استغلال المهاجمين لفارق التوقيت (NTP)	امتثال / أمني	مدير مركز العمليات	متوسط (8)	معالجة (Treat)	ربط جميع خوادم البنك بمصدر توقيت

محدد -Stratum 1 مترامن مع البنك المركزي، وتدقيق التزامن بصورة آلية كل ساعة.			SOC		Drift بمقدار 7 دقائق) للتلاعب بسجلات المعاملات، مما يحول دون إثبات الجرائم المالية والامتثال لتعليمات SAMA.	تفاوت التوقيت	
تفعيل سياسة SCP على مستوى الحساب المؤسسي لمنع إلغاء الحظر العام نهائياً، وتشفير البيانات عبر AWS KMS.	معالجة (Treat)	عالي (12)	مدير السحابة	سمعة / رقابي	قيام مطور أو مسؤول نظام بتغيير أذونات مستودع AWS S3 عن طريق الخطأ لجعله متاحاً للعمامة، مما يؤدي لتسريب مستندات وتقارير مالية للجمهور.	انكشاف مستودع سحابي يحوي بيانات حساسة	6
إعادة هيكلة أذونات NTFS وحصرها بقائمة محددة بالاسم، وتفعيل نظام تدقيق ومراقبة وصول الملفات File Auditing.	معالجة (Treat)	متوسط (6)	مديرة الموارد البشرية	داخلي / خصوصية	استغلال موظف في تقنية المعلومات لصلاحياته الموروثة في الدليل النشط لفتح المجلدات المشتركة لإدارة الموارد البشرية والاطلاع على رواتب القيادات.	اطلاع غير مخول على ملفات الرواتب	7
الاشتراك في خدمة الحماية السحابية من هجمات الحجب (Cloud DDoS) Mitigation مع مراقبة حركة المرور وتوفير مسارات بديلة.	معالجة (Treat)	عالي (12)	مدير الشبكات وأمن المحيط	تشغيلي / سمعة	شن هجوم حجب خدمة موزع ضخم على بوابات الصيرفة الإلكترونية وموقع البنك مما يؤدي لشلل الخدمات الرقمية وتدمير العملاء وخسائر تجارية.	انقطاع الخدمة بهجوم حجب الخدمة (DDoS)	8
إلزام الموردين بتطبيق ضوابط ISO 27001، وفحص التحديثات في بيئة معزولة (Sandbox)، ومراجعة العقود الدورية.	معالجة (Treat)	عالي (12)	مدير مشتريات التقنية والامتثال	سلسلة توريد	استهداف أحد موردي البرمجيات المتعاقد معهم واختراق خوادم التحديثات لديهم لدس كود خبيث داخل أنظمة البنك (هجوم سلسلة التوريد).	اختراق قناة التحديثات البرمجية للموردين	9
حظر منافذ USB بالكامل عبر سياسات Intune GPO، وتفعيل نظام منع تسريب البيانات Endpoint DLP، وتطبيق التنبيه الآلي.	معالجة (Treat)	عالي (12)	مدير أمن المعلومات (CISO)	داخلي / تسريب بيانات	قيام موظف مستقبل أو غير راض بنسخ قواعد بيانات العملاء أو ملفات سرية على قرص تخزين خارجي (USB) لبيعها أو استغلالها.	تسريب بيانات عبر وسائط التخزين USB	10

مرجع: الجدول 4: ملخص نتائج تقييم المخاطر القائم على السيناريوهات

4 الملحق أ: التقييم المفصل للمخاطر (Appendix A: Detailed Risk Assessment)

يوثق هذا الملحق التحليل المعمق لكافة عناصر تقييم المخاطر، متضمناً الأصول، التهديدات، نقاط الضعف القائمة، الضوابط الأمنية الحالية، وتقدير مستويات الاحتمالية والأثر قبل المعالجة (الخطر الأولي Inherent Risk)، ثم قرار المعالجة، والضوابط المقترحة المستمدة من الملحق (A) لمواصفة ISO/IEC 27001:2022، ومستوى الخطر المستهدف المتبقي بعد تطبيق خطة المعالجة.

البيان: الشكل 1 / جدول المصفوفة التفصيلية لتقييم ومعالجة المخاطر:

الرقم	الأصل / السيناريو	التهديد ونقطة الضعف	الضوابط الحالية	الأثر	الاحتمال	الخطر الأولي	خيار المعالجة	الضوابط المقترحة ISO 27001	الخطر المتبقي
RSK 01-	أجهزة المستخدمين (2000 لابتوب)	فقدان أو سرقة الجهاز / عدم تفعيل التشفير الشامل للقرص	كلمات مرور محلية فقط ومضاد فيروسات تقليدي	4	4	16 (حرج)	تخفيف (Mitigate)	A.8.1 التشفير الشامل BitLocker، XTS-AES 256، وA.8.7 حظر وسائط USB عبر Intune	4 (منخفض) L=2, I=2
RSK 02-	البريد الإلكتروني والموظفون	هجمات التصيد الاحتمالي الموجه / ضعف الوعي الأمني (8% إبلاغ)	فترة بريد أساسية دون محاكاة أو تدريب	4	4	16 (حرج)	تخفيف (Mitigate)	A.6.3 التوعية والتدريب الدوري، وA.8.20 زر التبليغ المباشر في Outlook وفترة الروابط	4 (منخفض) L=2, I=2
RSK 03-	قواعد بيانات النظام المصرفي الأساسي	هجمات الفدية وتشفير السجلات / ثغرات في الشبكة وصلاحيات مفرطة	جدار حماية داخلي ونسخ احتياطي يومي تقليدي	5	3	15 (عالي)	تخفيف (Mitigate)	A.8.13 النسخ غير القابل للتعديل، WORM، وA.8.24 تشفير قواعد البيانات TDE وعزل الشبكة	5 (متوسط) L=1, I=5
RSK 04-	تطبيقات الصيرفة الرقمية (Web/App)	استغلال ثغرات الويب والتلاعب بواجهات API / ثغرات برمجية غير مكتشفة	مراجعة كود يدوية وشهادة SSL قياسية	4	3	12 (عالي)	تخفيف (Mitigate)	A.8.25 تطوير البرمجيات الآمن، وA.8.26 فحص الثغرات، DAST/SAST، وWAF حماية	4 (منخفض) L=1, I=4
RSK 05-	خوادم الدومين والدليل النشط (AD)	تصيد الصلاحيات والاستيلاء على الدومين / استخدام بروتوكولات قديمة	سياسات كلمات مرور تقليدية دون إدارة PAM	4	3	12 (عالي)	تخفيف (Mitigate)	A.8.2 إدارة الحقوق المتميزة، PAM، وA.8.9 إلغاء NTLMv1/SMBv1 وتطبيق LAPS	4 (منخفض) L=1, I=4
RSK 06-	المستودعات السحابية (AWS S3)	انكشاف مستودعات التخزين للعامة / خطأ	إعدادات أذونات افتراضية للمشاريع	4	3	12 (عالي)	تخفيف (Mitigate)	A.5.23 أمن الخدمات السحابية، وA.8.10 منع تسريب البيانات، وتفعيل S3 Block	3 (منخفض) L=1, I=3

	Public Access					السحابية	بشري في إعداد أذونات السحابية		
RSK 07-	تطبيق الرواتب التراشي Syberola ()	استغلال ثغرات غير مدعومة / تطبيق قديم بانتظار الاستبدال	عزل جزئي في شبكة VLAN فرعية	3	3	9 (متوسط ط)	قبول مشروط (Accept)	A.8.19 تثبيت التحديثات، وعزل الخادم بالكامل حتى استبداله خلال شهرين في Q3-2026	6 (متوسط) L=2, I=3
RSK 08-	سجلات الأحداث الأمنية ومزامنة الوقت	فقدان الأدلة الجنائية والنزاعات المصرفية / انحراف توقيت NTP (7 دقائق)	خوادم وقت داخلية غير موحدة وبلا تدقيق	4	2	8 (متوسط ط)	تخفيف (Mitigate)	A.8.17 مزامنة السجلات مع خادم وقت البنك المركزي Stratum-1 وحماية السجلات من الحذف	2 (منخفض) L=1, I=2
RSK 09-	مجلدات الموارد البشرية المشتركة	اطلاع غير مخول من موظفي تقنية المعلومات / صلاحيات موروثة فضفاضة	أذونات مشاركة ملفات ويندوز اعتيادية	3	2	6 (متوسط ط)	تخفيف (Mitigate)	A.5.15 التحكم في الوصول، وحصر الصلاحيات بالاسم وتفعيل مراقبة وصول الملفات	2 (منخفض) L=1, I=2
RSK 10-	بوابات الدفع وشبكة سويفت	اختراق محطة سويفت والتحويل الاحتيالي / استهداف برمجيات المورد	جدران حماية معتمدة وتطبيق متطلبات SWIFT الأساسية	5	2	10 (متوسط ط)	تخفيف (Mitigate)	A.5.19 أمن سلاسل التوريد، والامتثال الصارم لبرنامج SWIFT CSP توقيع إلكتروني مزدوج	5 (متوسط) L=1, I=5

ملاحظة ختامية: جدول تفصيلي يوضح مصفوفة تقييم ومعالجة المخاطر مع توزيع درجات الأثر والاحتمالية وفق ISO/IEC 27001:2022